Лабораторна робота № 4

Тема: «Дослідження систем захисту захищених месенджерів».

Виконали: Остаповець Олеся Віталіївна та Булигін Олексій Михайлович, група ФІ-52мн.

Мета роботи та використані джерела

Мета роботи — дослідити принципи захищеного обміну повідомленнями, механізми наскрізного шифрування (E2EE), моделі загроз та особливості криптографічного захисту в сучасних месенджерах.

Робота має аналітичний характер. Використано технічні специфікації Signal Protocol, офіційну документацію Signal, WhatsApp, Telegram та Rakuten Viber. Проаналізовано актуальні механізми постквантового захисту. Матеріали опрацьовано станом на 30.10.2026; повні посилання наведено в кінці звіту.

1. Дослідження принципів наскрізного шифрування

1.1. TLS і наскрізне шифрування (E2EE)

TLS захищає канал між двома сусідніми учасниками мережевої взаємодії, наприклад застосунком і сервером месенджера. На сервері TLS-з’єднання завершується: якщо вміст повідомлення не зашифрований окремо, сервер може його прочитати. TLS також не гарантує конфіденційність повідомлень після їхнього збереження на сервері.

E2EE передбачає шифрування на пристрої відправника й розшифрування лише на пристроях адресатів. Сервер пересилає шифротекст, але не володіє необхідними ключами. Воно краще захищає від компрометації сервера, проте не захищає від читання вже розшифрованих повідомлень на зараженому або розблокованому пристрої [1, 5].

1.2. Довгострокові ключі ідентифікації та сеансові ключі

Identity key — відносно постійна пара ключів, що слугує криптографічною основою ідентичності пристрою або облікового запису. За нею співрозмовник може перевірити, що спілкується з тим самим вузлом. **Session key** — тимчасовий симетричний ключ (або ключовий матеріал), який використовується для конкретного сеансу чи повідомлення.

Розділення ролей обмежує наслідки компрометації: постійний ключ не повинен безпосередньо шифрувати всю історію повідомлень, а старі сеансові ключі необхідно знищувати після використання [1, 2].

1.3. Узгодження спільного секрету через недовірений сервер

Відправник отримує автентичний відкритий ключ адресата і виконує протокол узгодження ключів, наприклад на основі (еліптично-кривого) Діффі — Геллмана. Кожен бік обчислює однаковий спільний секрет зі свого закритого ключа та відкритого ключа іншого боку. У Signal для початкового встановлення сеансу використовується гібридний механізм PQXDH, який поєднує класичне узгодження ключів із постквантовим [2].

Недовірений сервер може передавати відкриті ключі, але не має змоги самостійно обчислити секрет без закритих ключів. Водночас підміна відкритого ключа створює ризик MITM, тому необхідні автентифікація ключів та їхня перевірка поза цим каналом.

1.4. Forward Secrecy

Forward Secrecy (FS) означає, що компрометація поточного довгострокового ключа або пізнішого стану сеансу не дає змоги відновити ключі давно завершених обмінів, якщо старі секрети належним чином видалено. Це зменшує наслідки викрадення ключів після того, як зловмисник уже записав зашифроване листування [1].

1.5. Post-Compromise Security

Post-Compromise Security (PCS) — здатність протоколу відновити конфіденційність наступних повідомлень після тимчасового розкриття ключового стану, коли зловмисник більше не контролює пристрій і відбувається коректне внесення свіжого секрету. Різниця: FS захищає минуле від майбутньої компрометації, а PCS — майбутнє після минулої компрометації [1, 3].

PCS не гарантує захисту, якщо зловмисник залишається на пристрої, постійно читає ключі або підміняє учасників сеансу.

1.6. Навіщо змінювати ключі під час листування

Постійне застосування одного ключа означало б, що його витік розкриває великий обсяг листування. Похідні ключі для кожного повідомлення й періодичне узгодження нових секретів зменшують «вікно компрометації», підтримують FS та дають передумови для PCS. Використані ключі видаляються, а нові виводяться криптографічними функціями KDF [1].

1.7. Double Ratchet

Double Ratchet поєднує два процеси оновлення ключів. Симетричний ratchet (KDF-ланцюжок) виводить окремий ключ для кожного повідомлення. Ratchet на основі Діффі — Геллмана періодично додає новий секрет під час обміну повідомленнями у відповідь. Комбінація обмежує наслідки розкриття попередніх ключів і за належних умов забезпечує відновлення захисту після компрометації [1].

1.8. Перевірка співрозмовника

Safety number, fingerprint або QR-код — це зручне представлення криптографічного ідентифікатора ключів співрозмовників. Користувачі мають порівняти його через незалежний автентичний канал (наприклад особисто або голосом, якщо особу перевірено). Збіг допомагає виявити підміну ключів сервером або посередником. У Signal використовується safety number; у WhatsApp — код безпеки/QR; у Telegram Secret Chats — візуалізація ключа; у Viber — Trusted contacts [4, 7, 9, 11].

2. Порівняння захищених месенджерів

Розглянуто саме особисті чати, звичайні групи та дзвінки, без ототожнення їх із каналами, спільнотами або ботами. Реалізація захисту залежить від типу спілкування [5–12].

Таблиця 1 — Порівняння криптографічних властивостей месенджерів

Критерій	**Signal**	**WhatsApp**	**Telegram**	**Viber**
E2EE особистих чатів	Так	Так, для приватних чатів	Лише Secret Chats; звичайні cloud-чати — ні	Так
E2EE за замовчуванням	Так	Так, у приватних чатах	Ні; Secret Chat треба почати окремо	Так, у приватних чатах
Групові чати	E2EE	E2EE	Звичайні групи — без E2EE	E2EE у групах; канали/спільноти — без E2EE
Голосові й відеодзвінки	E2EE, включно з груповими	E2EE для приватних і групових дзвінків	E2EE індивідуальних та нових групових дзвінків; інші формати трансляцій відрізняються	E2EE лише дзвінків 1:1; групові дзвінки — ні
Перевірка особи	Safety number / QR	Security code / QR	Візуалізація ключа Secret Chat; перевірка емодзі дзвінка	Trusted contacts, перевірка ключа
Forward Secrecy	Так; ratchet, ротація ключів	Так у Signal-подібному протоколі	Secret Chats: ротація E2EE-ключів; cloud-чати: PFS клієнт-серверного каналу	Так, власна реалізація double ratchet

Критерій	Signal	WhatsApp	Telegram	Viber
Історія й резервні копії	Історія на пристроях; опційні E2EE Signal Secure Backups	Історія на пристроях; E2EE хмарних копій налаштовується окремо	Cloud-чати зберігаються в хмарі й доступні з пристроїв; Secret Chats — локально	Історія на пристроях; копії iCloud/Google Drive не захищені E2EE Viber
Метадані для сервісу	Мінімізовані: дані маршрутизації, мережеві сигнали, час доставки	Номери/контакти в межах функцій, членство у групах та службові сигнали	Дані облікового запису, cloud-чатів і маршрутна інформація	Номер, адресна книга за умовами доступу, сервісні метадані

Аналіз. Саме формулювання «шифрування є» не визначає рівень захисту. По-перше, шифрування лише до сервера не дорівнює E2EE: Telegram cloud-чати шифруються в транспорті та на інфраструктурі сервісу, але серверна архітектура принципово інша, ніж Secret Chats. По-друге, E2EE одного типу комунікації не поширюється автоматично на інший: Viber не захищає ним групові дзвінки та канали, тоді як Telegram окремо підтримує E2EE групових дзвінків. По-третє, захист резервних копій, метаданих і пристроїв потребує додаткових механізмів [5–12].

За критерієм мінімізації доступу оператора до вмісту **Signal, WhatsApp і приватні чати Viber** забезпечують E2EE за замовчуванням; для Telegram користувач має явно обрати Secret Chat. Це не означає, що один додаток автоматично усуває всі загрози: важливі довіра до пристрою, коректна перевірка ключів, тип групи та резервне копіювання.

3. Аналіз ситуацій порушення безпеки

3.1. Компрометація сервера месенджера

Доступні дані. За коректного E2EE сервер не може прочитати текст та вкладення, оскільки не має ключів розшифрування. Однак зловмисник може отримати чергу шифротекстів, частину ідентифікаторів користувачів, час і розмір повідомлень, IP-адреси або службові дані — залежно від архітектури та політики мінімізації метаданих.

Захист. E2EE залишає ключі на кінцевих пристроях, а автентифіковане шифрування запобігає непомітній зміні шифротексту. Перевірка fingerprint зменшує ризик підміни ключа при встановленні нового сеансу.

Обмеження. Сервер усе ще здатен не доставляти, затримувати, дублювати повідомлення, виконувати аналіз трафіку, намагатися підмінити відкритий ключ у неперевірених сеансах або впливати на доступність. E2EE не гарантує захист від цих дій без додаткових протокольних перевірок.

3.2. Компрометація кінцевого пристрою

На розблокованому смартфоні повідомлення вже є у відкритому вигляді в застосунку. Зловмисник може прочитати історію, зняти скриншоти, отримати доступ до ключів або відправити повідомлення від імені власника. E2EE захищає передавання, але не може захистити текст, який законний застосунок уже розшифрував.

Необхідні окремі засоби: блокування пристрою, шифрування локального сховища, своєчасні оновлення, мінімізація дозволів, захист від шкідливого ПЗ, перевірка прив’язаних пристроїв і можливість завершити сесії.

3.3. Компрометація ключового матеріалу одного сеансу

Якщо викрадено **лише ключ конкретного повідомлення**, зловмисник може розшифрувати відповідне повідомлення, але не повинен отримати інші ключі з одностороннього KDF-ланцюжка. Якщо викрадено **поточний стан ratchet**, можуть бути доступні декілька наступних повідомлень до внесення нового, невідомого зловмиснику секрету. Реальні межі залежать від того, який саме стан украдено й чи збережено старі ключі.

FS захищає попередні повідомлення за умови видалення старих ключів. **PCS** може повернути захист наступних повідомлень після нової криптографічної ротації, але не під час постійного контролю зловмисника над пристроєм. Сам факт ротації симетричних ключів без свіжого недоступного атакувальнику секрету не гарантує PCS [1].

3.4. MITM під час першого встановлення зв’язку

Alice та Bob можуть обчислити ключі через сервер, але якщо сервер підмінить відкриті ключі, кожен фактично створить окремий захищений канал зі зловмисником. Тоді посередник розшифровуватиме, змінюватиме й повторно шифруватиме повідомлення, а обидва користувачі бачитимуть «зашифроване з’єднання».

Порівняння safety number, fingerprint або QR-кодів незалежним перевіреним каналом зв’язує отримані ключі з реальною особою. Якщо значення не збігаються або несподівано змінилися, учасники мають припинити передавання конфіденційних даних і повторно перевірити співрозмовника.

3.5. Резервне копіювання повідомлень

Повідомлення може бути зашифроване під час передавання, але зберігатися в резервній копії іншими засобами. Якщо сервер резервних копій, хмарний акаунт або адміністратор провайдера має доступ до ключа, компрометація копії може розкрити всю історію. Отже, E2EE в чаті саме по собі не гарантує E2EE його бекапу.

Щоб зберегти наскрізний захист, копія повинна шифруватися **на пристрої до відправлення** незалежним ключем, який контролює користувач; потрібно забезпечити безпечне відновлення ключа, автентифікацію, цілісність і захист від перебору пароля. Наприклад, Signal Secure Backups мають власний ключ відновлення; у WhatsApp

користувач може окремо увімкнути E2EE копій за допомогою ключа, пароля або passkey. Viber попереджає, що копії в iCloud/Google Drive більше не захищені його E2EE [6, 8, 12].

4. Постквантовий захист систем обміну повідомленнями

4.1. Сценарій Harvest Now, Decrypt Later

У моделі **Harvest Now, Decrypt Later (HNDL)** атакувальник зараз масово перехоплює та зберігає зашифрований трафік, а після появи достатньо потужного квантового комп’ютера намагається відновити ключі класичного асиметричного узгодження та розшифрувати архів. Навіть якщо дані не вдається прочитати сьогодні, їхня конфіденційність має значення протягом багатьох років.

4.2. Чому загроза актуальна вже зараз

Трафік можна записати задовго до появи квантового комп’ютера. Якщо майбутній алгоритм дозволить зламати класичні DH/ECDH-обміни, то збережені повідомлення, ключі яких були виведені тільки з такого обміну, можуть стати доступними для розшифрування. Це особливо важливо для медичних, юридичних, фінансових даних і довгострокових секретів [2, 3].

4.3. Які механізми потребують модернізації

Найважливіше замінити або доповнити **асиметричне встановлення ключів**, що спирається на RSA, DH та ECDH, оскільки великий квантовий комп’ютер із алгоритмом Шора здатен поставити під загрозу відповідні математичні задачі. Для автентифікації підписів також потрібен окремий план переходу на постквантові схеми. Симетричне шифрування та хеш-функції не зазнають такого самого типу зламу; достатні розміри ключів та параметрів зберігають їхню практичну роль.

4.4. Приклад Signal: PQXDH, SPQR і Triple Ratchet

PQXDH розширює початкове узгодження ключа: поєднує класичну частину на еліптичних кривих і постквантовий механізм інкапсуляції ключа. Секрет сеансу залежить від обох складових, тому для його розкриття недостатньо зламати лише класичну задачу. Специфікація PQXDH при цьому прямо зауважує, що автентифікація в цій версії ще не є повністю постквантовою [2].

Однак початкового гібридного обміну недостатньо для тривалого листування, особливо після компрометації стану. Тому Signal розробив **Sparse Post-Quantum Ratchet (SPQR)** — періодичне отримання нових постквантових секретів. Специфікація **ML-KEM Braid** описує постквантове неперервне узгодження ключів з властивостями FS та PCS. Класичний Double Ratchet і SPQR можна поєднувати в **Triple Ratchet**, де ключі повідомлень походять від обох механізмів [1, 3, 4].

Цей підхід є **гібридним**: він зберігає перевірені класичні гарантії та додає стійкість до майбутніх квантових атак. У документації Signal описано механізми й поетапне впровадження; конкретні гарантії залежать від версій протоколу на кінцевих пристроях [3].

4.5. Додаткова властивість безпеки

Порівняно зі схемою, де застосовується лише ECDH, гібридний протокол має зберегти конфіденційність архіву повідомлень навіть у випадку майбутнього квантового зламу класичного компонента. Post-quantum ratcheting додатково прагне забезпечити постквантові FS і PCS протягом тривалого листування, а не лише під час першого встановлення сеансу [1–4].

Висновки

Рівень захисту месенджера визначається не тільки наявністю шифрування, а й тим, **де саме зберігаються ключі, чи підтверджено співрозмовника, чи оновлюються ключі та як захищено резервні копії**. TLS забезпечує захист на мережевих ділянках, тоді як E2EE обмежує доступ оператора сервісу до вмісту повідомлень. Identity keys пов’язують ключі з користувачами, а сеансові ключі та Double Ratchet обмежують наслідки компрометації.

Signal, WhatsApp і приватні чати Viber застосовують E2EE за замовчуванням, тоді як Telegram обмежує його Secret Chats; умови захисту групових дзвінків і резервних копій відрізняються. Навіть коректний E2EE не протидіє читанню тексту на розблокованому пристрої, відмові в доставці або повному аналізу метаданих. Отже, криптографічний захист потребує безпечних пристроїв і незалежної перевірки ключів.

Постквантова модернізація Signal показує, як до класичного Double Ratchet можна додати PQXDH та постквантове оновлення секретів. Гібридний підхід має захистити записані сьогодні повідомлення від майбутнього квантового криптоаналізу й підтримати FS та PCS протягом сеансу.

Використані джерела

[1] Signal — The Double Ratchet Algorithm (включно з Triple Ratchet): https://signal.org/docs/specifications/doubleratchet/

[2] Signal — The PQXDH Key Agreement Protocol: https://signal.org/docs/specifications/pqxdh/

[3] Signal — Signal Protocol and Post-Quantum Ratchets: https://signal.org/blog/spqr/

[4] Signal — The ML-KEM Braid Protocol: https://signal.org/docs/specifications/mlkembraid/

[5] Signal Support — What is a safety number?: https://support.signal.org/hc/en-us/articles/360007060632-What-is-a-safety-number-and-why-do-I-see-that-it-changed

[6] Signal Support — Backups and Device Transfers on Signal: https://support.signal.org/hc/en-us/articles/10074659364122-Backups-and-Device-Transfers-on-Signal

[7] WhatsApp Help Center — About security code change notifications: https://faq.whatsapp.com/1524220618005378

[8] WhatsApp Help Center — About end-to-end encrypted backup: https://faq.whatsapp.com/490592613091019/

[9] Telegram — Telegram FAQ, Security, Secret Chats, Calls: https://telegram.org/faq

[10] Telegram — End-to-End Encryption, Secret Chats: https://core.telegram.org/api/end-to-end

[11] Rakuten Viber — Understanding end-to-end encryption: https://help.viber.com/hc/en-us/articles/8909167863453-Understanding-end-to-end-encryption

[12] Rakuten Viber — Teens privacy guide (про резервні копії): https://help.viber.com/hc/en-us/articles/25771800726557-Teens-privacy-guide

[13] Rakuten Viber — Encryption overview: https://www.viber.com/app/uploads/viber-encryption-overview.pdf

[14] WhatsApp — Privacy at a Glance: https://faq.whatsapp.com/236979282604093

[15] WhatsApp — Answering Your Privacy Questions: https://www.whatsapp.com/privacyquestions